

Retail & E-commerce — Canales digitales

Adecuación operativa al nuevo marco de protección de datos personales

Cookies opt-in, formularios granulares, remarketing y contratos DPA con agencias de marketing.

01-12-2026 Vigencia plena Régimen sancionatorio operativo	20.000 UTM Multa gravísima ~\$1.400 millones aprox.	+50% Recargo Si no subsana en 60 días
--	--	--

Datos clave del nuevo régimen

■ Vigencia plena

1 de diciembre de 2026

■ Notificación de brechas

Sin dilaciones indebidas a la Agencia y a los afectados

■ Delegado de Protección de Datos (DPO)

Generalmente voluntario (Art. 50); obligatorio por excepción legal

■ Reincidencia (grandes empresas)

Hasta 2%–4% de los ingresos brutos anuales

■ Recargo por no subsanar

50% adicional si no corrige en 60 días

Resumen ejecutivo

Lo esencial en 30 segundos

Las cookies de análisis y marketing deben estar desactivadas por defecto (opt-in): el consentimiento tácito ya no es válido y se sanciona hasta con 10.000 UTM. El SERNAC exige banners con dos botones equivalentes (rechazar = aceptar), panel de configuración desmarcado y revocación permanente. Formularios de leads sin casillas premarcadas; cada finalidad requiere consentimiento separado. Carritos abandonados y remarketing requieren consentimiento previo: la ejecución del contrato solo cubre pago, boleta y despacho. Agencias de marketing y plataformas de emailing son encargados: exigen DPA firmados.

1. Banner de cookies y rastreo digital (consentimiento opt-in)

Para los sitios web, landings y tiendas de e-commerce que operan en Chile, la Ley 21.719 cambia radicalmente el uso de scripts de seguimiento y marketing. Herramientas como Meta Pixel, Google Analytics, Google Ads y software de retargeting recopilan la dirección IP, dirección MAC o identificadores del dispositivo del usuario, los cuales son datos personales protegidos. Bajo el principio de privacidad por diseño, todas las cookies analíticas, de marketing o de seguimiento deben estar desactivadas por defecto al cargar el sitio. El consentimiento debe ser explícito (opt-in) mediante una acción afirmativa clara. El consentimiento tácito derivado de continuar navegando, o el uso de barras que solo informan que "usamos cookies", ya no es válido bajo la ley y constituye una infracción grave con multas de hasta 10.000 UTM.

2. Directrices del SERNAC para el diseño de canales y cookies

El SERNAC ha establecido directrices técnicas estrictas basadas en la protección al consumidor para evitar los "patrones oscuros" que manipulan o dirigen la voluntad del usuario: Diseño de dos botones equivalentes: el banner de cookies en la primera interacción debe presentar las opciones "Rechazar cookies adicionales" (o "Solo esenciales") y "Configurar/Aceptar" de forma clara, con el mismo peso visual, sin colores que dirijan hacia el botón de aceptar todo. Configuración desmarcada por defecto: al pulsar "Configurar", se debe abrir un panel con las categorías analíticas, funcionales y de marketing completamente desmarcadas, de modo que sea el usuario quien las active proactivamente. Revocabilidad sencilla: el usuario debe poder revocar su autorización en cualquier momento de manera tan rápida, directa y gratuita como la otorgó, mediante un botón permanente o widget flotante en el pie de página.

3. Consentimiento granular en formularios de contacto y leads

Se prohíbe el uso de checkboxes premarcados para suscribir a los usuarios a boletines de marketing digital o bases de datos de leads al momento de realizar una consulta técnica o cotización. Cada finalidad requiere consentimiento por separado. Una casilla voluntaria desmarcada debe indicar explícitamente: "Acepto recibir comunicaciones promocionales".

4. Límites en correos de carritos abandonados y remarketing

La base legal de "ejecución de contrato" (Artículo 13 letra b) legitima únicamente el tratamiento de datos para procesar el pago, emitir la boleta y despachar el producto comprado. El envío de campañas de correo comercial de carritos abandonados o remarketing personalizado con datos de navegación requiere inexcusablemente un consentimiento previo y granular del usuario, ya que sobrepasa los límites de lo estrictamente necesario para la transacción inicial.

5. Gobernanza de agencias y contratos de encargo (DPA)

El retail y e-commerce delega masivamente el tratamiento de datos de clientes a agencias de marketing digital, plataformas de emailing (Mailchimp, HubSpot) o sistemas de hosting. Esto califica como un encargo de tratamiento (Artículo 15 bis), obligando a suscribir contratos DPA con cláusulas explícitas que restrinjan el uso de los datos a los fines del e-commerce y garanticen medidas de seguridad técnicas avanzadas.

Casos típicos del sector

Situación	Gravedad probable
Un ecommerce muestra «Este sitio usa cookies» sin botón de rechazo, con Meta Pixel disparando desde la primera visita.	Grave
En el checkout, la casilla «Quiero recibir ofertas» viene marcada por defecto.	Grave
Marketing envía correos de carrito abandonado usando historial de navegación capturado sin consentimiento.	Grave

Régimen sancionatorio

Categoría	Sanción máxima	Ejemplos típicos
Leve	5.000 UTM	Incumplir plazos, no entregar información clara
Grave	10.000 UTM	Tratar datos sin base legal, vulnerar seguridad
Gravísima	20.000 UTM	Uso fraudulento, filtración intencional de datos sensibles

Infraacción	Techo en UTM	Equivalencia aprox.*
Leve	5.000 UTM	~ \$345 millones
Grave	10.000 UTM	~ \$690 millones
Gravísima	20.000 UTM	~ \$1.400 millones

*Valores referenciales con UTM de agosto 2026 (~\$69.000). El valor de la UTM se reajusta mensualmente según IPC.

■ Vigencia plena

1 de diciembre de 2026

■ Notificación de brechas

Sin dilaciones indebidas a la Agencia y a los afectados

■ Delegado de Protección de Datos (DPO)

Generalmente voluntario (Art. 50); obligatorio por excepción legal

■ Reincidencia (grandes empresas)

Hasta 2%–4% de los ingresos brutos anuales

■ Recargo por no subsanar

50% adicional si no corrige en 60 días

Checklist de implementación sectorial

1. Auditar exhaustivamente scripts, SDKs y píxeles instalados en el código del e-commerce (Wix,
2. Implementar un banner de gestión de consentimiento (CMP) con bloqueo automático de scripts
3. Deshabilitar definitivamente las casillas premarcadas en formularios de registro, contacto o sorteos.
4. Adaptar la política de privacidad del sitio identificando responsable, finalidades y plazos de
5. Garantizar un botón permanente de revocación rápida de cookies en el pie de página.
6. Firmar contratos de encargo DPA con agencias de marketing digital y proveedores SaaS críticos.

Hoja de ruta sugerida de implementación

Días 1–30 · Diagnóstico

Inventario RAT, mapa de flujos de datos y brecha frente a la ley.

Días 31–60 · Adecuación

Políticas actualizadas, contratos DPA, canales ARSOP y banners de consentimiento.

Días 61–90 · Cultura y pruebas

Capacitación, simulacro de brecha, revisión final y designación DPO si corresponde.

Preguntas frecuentes

¿Google Analytics y Meta Pixel necesitan consentimiento?

Sí. Son scripts de análisis y marketing no esenciales: deben permanecer bloqueados hasta que el usuario acepte de forma explícita.

¿Puedo mezclar la boleta con publicidad en un mismo correo?

El mensaje transaccional puede enviarse sin consentimiento; agregar promociones en ese mismo envío exige consentimiento de marketing separado y verificable.

¿Dónde debe estar el botón para revocar cookies?

Accesible y permanente: típicamente un enlace o widget flotante en el pie de página que reabra el panel de configuración con igual facilidad que la aceptación.

¿Cuánto tiempo puedo conservar los datos de despacho?

Solo lo necesario para garantías, tributos y atención postventa: definir política escrita de retención (por ejemplo 24 meses) con borrado automático posterior.

¿Si la agencia de marketing comete una fuga, quién responde?

El responsable (la tienda) responde frente a titulares y APDP; contra el encargado procede repetición contractual según el DPA firmado.

Glosario esencial

Dark patterns

diseños que manipulan la elección (botones desiguales, letra chica); prohibidos por directrices SERNAC.

CMP

plataforma de gestión de consentimiento que bloquea scripts hasta recibir opt-in y guarda evidencia de cada decisión.

Pixel / SDK de tercero

código de analítica o advertising (Meta Pixel, GA4) que recolecta identificadores del dispositivo: dato personal protegido.

Lead

contacto registrado para fines comerciales; su tratamiento requiere casilla voluntaria desmarcada por cada finalidad.

Remarketing

campañas dirigidas por comportamiento de navegación; exigen consentimiento previo granular.

ARSOP

Derechos de Acceso, Rectificación, Supresión, Oposición y Portabilidad que todo titular puede ejercer.

APDP

Agencia de Protección de Datos Personales: organismo fiscalizador del nuevo régimen.

RAT

Registro de Actividades de Tratamiento: inventario interno obligatorio de qué datos se tratan, para qué y con quién.

DPA

Data Processing Agreement o contrato de encargo de tratamiento entre responsable y encargado.

DPO

Delegado de Protección de Datos (Art. 50): figura generalmente voluntaria, obligatoria solo por excepción legal.

Brecha de seguridad

Pérdida, robo o acceso no autorizado a datos personales; debe notificarse sin dilaciones indebidas.

MPI

Modelo de Prevención de Infracciones: programa interno de cumplimiento que atenúa sanciones.

UTM

Unidad Tributaria Mensual, unidad monetaria indexada usada para calificar multas (reajustada por IPC).

Fuente oficial

Ley 21.719 — Biblioteca del Congreso Nacional de Chile (idNorma=1209272). Documento orientativo de trabajo; ante dudas específicas consultar siempre el texto vigente.